

מעבדה 08 — מחקר CVE ופגיעויות

Module 6 Day 2 | 2h | Browser + optional Kali



Lab Info

Module	Module 6
Topic	CVE, CVSS, NVD, Searchsploit, Exploit-DB, Risk Assessment
Duration	2h
Infra	Browser. Optional: Azure Cloud Shell for searchsploit

[.REF](#) Open **CVE & Exploit Research Cheat Sheet** from Toolbox

step 1

.Go to `https://nvd.nist.gov` . Search: `CVE-2021-44228` (Log4Shell)

step 2

.Read: Description, CVSS Score (10.0!), Vector, affected products

step 3

:Decode the vector

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H = 10.0`

`AV:N` = Network (remote attack)

`AC:L` = Easy to exploit

`PR:N` = No privileges needed

`UI:N` = No user interaction

⇒ Worst possible score

step 4

.Now search `CVE-2017-0144` (EternalBlue). Compare vectors

step 1

. `Apache 2.4.49` :Go to `https://exploit-db.com` . Search

step 2

.Look at results: Title, Type (webapps/remote), Platform. Click one to see exploit code

step 3

.From your Nmap results (Lab 02), search for vulnerabilities in services you found

step 1

```
searchsploit apache 2.4
searchsploit windows smb
searchsploit CVE-2021-44228
searchsploit -m 50383 # copy exploit locally
```

step 2

:Fill in

Service	Version	CVE	CVSS	Exploit?
OpenSSH	6.6.1p1	?	?	?
Apache	2.4.7	?	?	?

.TIP No Kali? Use exploit-db.com - same database, web interface

step 1

Scenario: web server has Apache 2.4.49 (port 80), OpenSSH 8.2 (port 22), SMB (port 445 open to .internet!)

Finding	CVE	CVSS	Exploit	Exposure	Risk
Apache 2.4.49	CVE-2021-41773	7.5	Yes	Internet	CRITICAL
SMB open	CVE-2017-0144	9.8	Yes!	Internet	CRITICAL
OpenSSH 8.2	?	?	?	Internet	?

step 2

.Write recommendations for each finding



Checklist

CVE looked up on NVD []

CVSS vector decoded []

Exploit-DB searched []

Searchsploit used (or web) []

Risk assessment completed []